

Policy-to-Purpose-to-Byte Continuity for Post-Quantum Peer-to-Peer Sessions

Anonymous Author(s)

Abstract—Post-quantum migration in long-lived peer-to-peer applications crosses signed policy, hybrid key establishment, authenticated handshake, asynchronous session ownership, and business-effect authorization. Existing work typically verifies only a subset of this chain. We propose *policy-to-purpose-to-byte continuity*: each endpoint accepts an application effect only if its local authenticated decision authorizes the same peer-visible policy, purpose, wire cryptographic profile, context, and transcript as the matching peer run; its exact local owner transaction has committed; and a purpose-specific effect receipt verifies. BOUNDSSESSION is designed to bind the purpose and policy projection into context-bound PQ/T key establishment, confirm the complete transcript, derive purpose-separated channel keys, and require bilateral authorization readiness before business data reaches a trusted effect committer. We also define a layered assurance boundary that keeps computational combiner binding, symbolic protocol analysis, state-machine checking, implementation conformance, final-binary evidence, and physical-device measurements distinct. This manuscript is an independent design-stage draft: the integrated proofs, final-source implementation, and cross-platform application experiments are deliberately reported as pending rather than inferred from component artifacts.

Index Terms—post-quantum cryptography, hybrid key encapsulation, authenticated key exchange, cryptographic agility, downgrade resistance, formal verification, peer-to-peer security

I. INTRODUCTION

POST-QUANTUM migration is often described as replacing a primitive. In a long-lived peer-to-peer (P2P) product, however, the security decision passes through policy distribution, provider selection, wire negotiation, key combination, application authorization, asynchronous ownership, and evidence generation. A failure at any boundary can invalidate a correct primitive: an old policy can be replayed, a provider can be re-selected after verification, a context field can be omitted, a stale connection can publish a new key, or an application can use a session before its security decision is committed.

Hybrid PQ/T key establishment combines a post-quantum KEM such as ML-KEM with a traditional component such as X25519. This hedges uncertainty about either component, but it does not by itself bind every relevant public value, policy choice, or application interpretation. Recent binding analyses show that key and ciphertext serialization choices can matter below the protocol layer [1], [2], [3]. At the other end of the stack, generic channel-binding and exporter mechanisms deliberately leave application-context semantics to the caller [4], [5]. Neither observation answers when a concrete application is authorized to consume a particular session.

This paper asks one question:

How can heterogeneous P2P endpoints ensure that a business capability is bound to the same authenti-

cated migration policy, application purpose, hybrid realization, transcript, and current session owner?

We call this property *policy-to-purpose-to-byte continuity*. Here “byte” means the exact canonical bytes consumed by the KEM context, signed transcript, key schedule, grant, and receipt encoders, together with conformance evidence for their final implementations. It does not mean business payload, remote attestation, or a verified source-to-binary compiler. The proposed protocol, BOUNDSSESSION, treats the application capability—not successful key derivation—as the acceptance event. A closed purpose type distinguishes, for example, view-only remote desktop, interactive control, and a particular content-addressed file transfer. The purpose is bound into the pre-KEM context, the signed transcript, the key schedule, the exact-owner commit, and the final application receipt.

Intended contributions. This design-stage manuscript is organized around three intended contributions, each gated by the evidence ledger shipped with the draft.

- 1) A single policy-to-purpose-to-byte contract that makes local provider refinement, downgrade behavior, purpose authorization, session ownership, and authorization-before-publication plus effect correspondence one security surface.
- 2) A layered formal argument: a computational binding result is used only as a component premise, a new active-attacker protocol model establishes agreement and secrecy at the composed message boundary, and a separate state model covers monotonic policy and asynchronous publication. We do not call conformance evidence a mechanized implementation refinement.
- 3) One portable protocol core and a source-bound evaluation that measures matched cryptographic baselines, adversarial ablations, real non-Apple interoperability, and purpose-specific physical-device receipts from the final candidate.

Draft status. No integrated theorem or measurement is claimed in this version. Numerical results will enter the manuscript only after their raw inputs and final source identity are selected by one immutable evidence manifest.

II. BACKGROUND AND RELATED WORK

A. Migration and downgrade

TLS 1.3 provides a mature authenticated channel and binds negotiated parameters into its transcript [6]. Fallback signaling can detect selected legacy downgrades [7], while NIST guidance treats crypto agility as an operational lifecycle rather than an algorithm toggle [8]. Our focus is narrower than

a general secure transport and broader than a fallback signal: a policy-bound attempt must determine which business capability, if any, can be released after every subsequent boundary.

B. Hybrid binding and realization

ML-KEM is standardized in FIPS 203 [9]. Binding-security work studies whether a KEM or combiner commits an accepted key to ciphertext and public-key inputs [1], [2], [3]. X-Wing is an important lean hybrid design point [10]. BOUNDSESSION does not claim a new primitive merely for hashing more fields. Its proposed contribution is a composed authorization invariant whose cryptographic projection uses a binding-safe component.

C. Formal and implementation assurance

EasyCrypt supports machine-checked computational proofs [11]; Tamarin and ProVerif support symbolic protocol analysis [12], [13]. Verified cryptographic libraries demonstrate stronger source-level implementation links than cross-language test vectors alone [14], [15]. We therefore label each assurance layer precisely instead of treating multiple tools as an end-to-end proof of a binary.

D. Authorization, recovery, and audit

Complete mediation and least privilege motivate checking authority at every use; capabilities make object-specific authority explicit [16], [17]. Crash-safe verification shows that authorization-before-publication must survive recovery [18], while secure audit logs offer stronger tamper-resistance than a local record [19]. These are foundations, not novelty claims. BOUNDSESSION composes them with policy-bound hybrid establishment, exact asynchronous ownership, and purpose-specific effects in one acceptance invariant.

III. SYSTEM AND THREAT MODEL

A. System boundary

Two previously paired endpoints in one managed policy domain establish a purpose-specific P2P session. On each endpoint, a separate trusted policy service (or an equivalently isolated boundary) owns a pinned policy root, monotonic policy state, the hybrid KEM identity, local owner registry, and server-side decision entries. Sealed presentation, input, and durable-file committers are also inside this boundary, together with the transactional store, crypto/identity ports, and receipt-key service. Effect committers execute or directly observe only their defined platform effect and cannot accept a caller-supplied success result. The service authenticates callers with OS IPC credentials and binds each handle to a caller principal, peer, purpose, local owner, epoch, expiry, and one-time operation sequence. Application modules, general platform adapters, discovery, and transports are outside that boundary. They may request a purpose but cannot construct, transfer, widen, or alter a decision or receipt.

An implementation that runs this boundary in the application's address space is an explicit honest-host profile and cannot claim resistance to hostile local modules. Peers agree

on a wire cryptographic profile, not on byte-identical local provider implementations.

The design has one protocol core. Swift, Kotlin, C, and other bindings perform marshalling and platform I/O; they do not implement independent suite, fallback, transcript, or ownership state machines.

B. Adversary

The remote adversary controls the network: it observes, drops, delays, reorders, duplicates, replays, injects, and currently triggers pre-authentication input. It may compromise selected long-term identity, KEM, or ephemeral keys at times made explicit by each theorem. An untrusted application module may call public APIs and race session replacement, but cannot read or execute inside the trusted policy or effect-committer boundary.

The base claims exclude compromise of the trusted policy/session service, transactional store, crypto/identity ports, receipt-key service, trusted effect committer, OS, root, or build host. They also exclude malicious compilers, universal denial-of-service resistance, remote attestation of peer policy execution, metadata unlinkability, and rollback of the entire device. Audit integrity is scoped separately: without an external witness, a local hash chain is diagnostic evidence, not durable non-repudiation.

C. Security goal

Let x collect the peer identities, peer session, policy, wire profile, purpose, context and transcript digests, shared grant and bilateral-ready digests, and a model-level shared purpose-key-schedule identifier. The last is neither a wire value nor an endpoint-private key handle. Let $\ell_A = (d_A, e_A, o_A, v_A)$ contain A 's local decision, decision epoch, owner binding, and provider identity, with ℓ_B defined symmetrically. For effect receipt r , the central local-to-peer correspondence is below; B denotes the endpoint that commits the purpose-defined effect.

$$\begin{aligned}
 \text{Accept}_A(x, \ell_A, r) \Rightarrow & \exists! \ell_B : \text{Run}_B(x, \ell_B) \\
 & \wedge \text{Permit}_A(x, \ell_A) \\
 & \wedge \text{Permit}_B(x, \ell_B) \\
 & \wedge \text{Finished}_{A,B}(x) \\
 & \wedge \text{OwnerTxn}_A(\ell_A) \\
 & \wedge \text{OwnerTxn}_B(\ell_B) \\
 & \wedge \text{Enable}_A(x, \ell_A) \prec \text{Publish}_A \\
 & \wedge \text{Enable}_B(x, \ell_B) \\
 & \wedge \exists! \text{EffectCommit}_B(x, r) \\
 & \wedge \text{Enable}_B \prec \text{EffectCommit}_B \\
 & \wedge \text{EffectCommit}_B \prec \text{ReceiptIssued}_B \\
 & \wedge \text{ReceiptOK}_A(x, r).
 \end{aligned} \tag{1}$$

The matching peer run agrees on the wire profile, not the private local provider v_B . The complete theorem must state compromise escapes, hybrid-secrecy premises, effect durability or application semantics, receipt ordering, and the

exact meaning of $\prec$ in the state model. For endpoint E , Enable_E abbreviates only its local chain: authorization precedes sending its ready value, and receipt of the peer ready value precedes its final owner CAS and enable event. No cross-host atomic commit, simultaneous enablement, or global-clock order is claimed. The effect-producing endpoint must itself be enabled, and its trusted purpose adapter must commit the unique effect before issuing r ; receipt syntax alone implies neither fact. Equation (1) does not claim that a remote endpoint's policy report or provider execution is hardware-attested.

IV. THE POLICY-TO-PURPOSE-TO-BYTE CONTRACT

A. Policy snapshot and local decision

A signed policy and monotonic compare-and-swap first yield an immutable policy snapshot. The trusted service then authenticates a session request and creates a local decision bound to the caller, local identity and role, expected peer, exact purpose, exact local owner, protocol version, one wire profile, one local provider, endpoint-private typed effect scope, policy identity, and decision epoch. No later layer may consult UI state, environment state, or a second selection policy. The peer-visible decision digest excludes the private local provider and owner; each endpoint separately proves that its local decision refines to a compliant implementation of the agreed wire profile. The handle is a caller-bound, non-serializable reference to service state, not a forgeable or reflective IPC data object.

B. Closed purpose and canonical context

The purpose is a closed tagged union. A remote-desktop value binds view-only or interactive authorization and a canonical capability bitmap. A file-transfer value binds role-relative direction, transfer identifier, declared length, and SHA-256 digest. Policy authorizes the exact peer and purpose before creating the local decision. Generic metadata maps and caller-defined strings are rejected.

$\text{BoundSessionContextV1}$ is a prefix-free canonical encoding of roles, peer identities, recipient KEM-key digest, the peer-visible decision projection, full purpose, client nonce, and a fresh peer-agreed session identifier. BoundSessionV1 has no suite re-selection and no simultaneous-open subprotocol: an outer arbiter chooses one initiator and transport owner first. Each endpoint's connection generation remains private local state. Unknown critical fields, duplicates, non-canonical order, overflow, and trailing bytes fail before KEM execution.

The pre-KEM context cannot contain a responder nonce or ciphertext that does not yet exist. Message signatures and the root key schedule therefore bind the later complete transcript. This two-stage construction avoids a circular definition while keeping pre-KEM and final-transcript agreement as separate proof obligations.

C. Grant authorization, bilateral readiness, and receipt

Message A authenticates the exact context projection and initiator KEM material. Message B confirms the fixed wire profile and authenticates both identities and nonces, responder material, and Message A. Direction-specific Finished messages

confirm the complete transcript. A second key schedule separates remote video, input, file, and control channels by purpose and direction.

After Finished, each local transaction compare-and-swaps its exact private owner and decision epoch, then atomically stores a pending grant and a matching authorization record. The record covers the complete local security tuple and means "this service authorized this grant," not application success. Each endpoint then sends an authenticated GrantReadyV1 . A canonical shared grant identifier covers the ordered peers, policy, wire profile, peer session, purpose, context, and transcript; a role-ordered digest covers both ready messages. Local grant identifiers, decision epochs, owners, and commit identifiers remain private. Before enabling and publishing BoundSessionGrant , the service again validates its exact owner and stores the bilateral-ready digest. Crash recovery revalidates and resumes the same pending transition or revokes it.

Business success requires a direction-specific, purpose-keyed receipt binding the shared grant, bilateral-ready digest, issuer authorization commitment, purpose, context, transcript, operation, sequence, result, and effect digest. Only the corresponding sealed purpose committer may report success: ordinary application code cannot choose the result or digest. Remote presentation means a completed trusted renderer fence, control means the OS input API accepted the exact action, and file success requires verified bytes plus the defined durable-store commit.

D. Failure and downgrade

A policy-bound PQ/T attempt cannot yield a business-capable classic session. Timeout, network manipulation, overload, cancellation, parse failure, identity failure, ABI failure, and provider failure terminate explicitly. A separately identified compatibility protocol may carry an authenticated endpoint declaration, but that declaration cannot prove the truth of a local hardware failure. A control-only bootstrap purpose cannot derive business keys before the required PQ/T rekey.

V. LAYERED SECURITY ANALYSIS

The proof plan deliberately separates claims that rely on different models. The combiner layer should establish canonical-encoding injectivity and binding under stated computational assumptions. A new Tamarin theory should model the actual BOUNDSESSION messages, signed decision identity, purpose, two-stage context, Finished exchange, compromises, and application acceptance under an active network adversary. A second state model should cover policy CAS, crash/restart, owner replacement, bilateral readiness, policy update, effect journaling, and publication.

The complete responsibility matrix is maintained with the formal composition boundary and will move to the supplement once theorem and artifact names are stable. A check at one assurance layer never discharges another layer.

The minimum theorem set includes policy-snapshot origin and monotonicity, exact peer-and-purpose authorization by each local decision, local provider refinement to the agreed wire profile, no policy-bound business fallback, canonical

pre-KEM context agreement, Finished injective agreement, hybrid secrecy with explicit compromise conditions, no cross-purpose key reuse, exact local-owner transaction, bilateral-ready agreement, policy-update semantics, trusted effect authority, authorization-before-publication, and authenticated receipt-to-effect correspondence. A static KEM suite must also include an attack witness showing the absence of forward secrecy after later static KEM-key compromise unless a fresh ephemeral contribution is specified and proved.

Component binding plus a symbolic protocol proof is not a complete computational AKE proof. Likewise, vectors, hashes, and source-bound execution are conformance evidence rather than a mechanized specification-to-binary refinement. These limits remain in the abstract, threat model, and conclusion after results are added.

VI. IMPLEMENTATION PLAN AND EVIDENCE CHAIN

The intended implementation has a portable Rust protocol core and narrow ports for policy, KEM, identity, transactional storage, transport, diagnostic audit, authenticated IPC, time, and three typed effect committers. Platform bindings own memory-safe marshalling and I/O. Application modules consume only typed grants. Existing component implementations may be reused behind ports only after their revisions, assumptions, and error semantics are pinned; obsolete parallel protocol paths are removed rather than hidden behind compatibility wrappers.

Every asynchronous boundary revalidates the exact private local owner tuple. Owner/decision compare-and-swap occurs both in the pending-grant authorization transaction and immediately before bilateral enable, with no external await in either transaction. Caller-bound handles, queues, parser inputs, pre-authentication state, file sizes, operation sequences, and audit retention have explicit limits, expiry, revocation, and release rules. Expensive signature and KEM work is admitted only after the cheapest trustworthy identity and resource checks.

One evidence manifest selects the final normative specification, formal models, proof reports, source, generated bindings, dependency identities, binaries, device runs, raw samples, and table generators. The machine-readable claim ledger distinguishes design, formal, conformance, runtime, physical-device, performance, artifact, and publication states.

VII. EVALUATION PLAN

The final evaluation is organized by four research questions rather than by component inventory.

RQ1: Does the contract prevent cross-policy, cross-purpose, and downgrade acceptance? We will execute active attacks that strip or replace policy, wire profile, purpose, context, key shares, transcript fields, Finished, shared-grant/ready values, local owner changes, trusted-effect outcomes, and receipts. Security-event results will be reported as x/N with Wilson intervals; unreachability claims come only from a model.

RQ2: Which bindings are load-bearing? Matched ablations remove policy digest, purpose, public key, ciphertext, attempt declaration, owner check, audit ordering, either ready message, bilateral-ready digest, shared-grant binding, trusted-effect authority, effect-journal ordering, and channel separation

one at a time. A deliberately unsafe timeout fallback is labeled an ablation, not a baseline implementation of TLS or QUIC.

RQ3: Does one final core execute consistently across substrates? Canonical vectors, independent decoders, cross-language differential tests, ABI fuzzing, sanitizers, and a two-ISA binary constant-time discriminator run from the final evidence root. At least one real non-Apple endpoint must complete the same authenticated protocol and application receipt with an Apple endpoint; cross-compilation and static contract checks do not count as runtime cells.

RQ4: What is the application cost? Matched final-source baselines use the same application, transport, endpoints, and completion definition. Remote desktop is the primary performance/QoE workload and reports handshake-to-first-frame, input-to-authenticated-apply receipt, frame quality, CPU, memory, and energy. File transfer is retained as an independent cross-purpose correctness, attack, and durable-receipt workload; its extended performance appears only in the supplement. Primary non-inferiority margins and experimental units are declared before capture.

Independent process batches are the experimental unit; frames within one trace are not independent sessions. Reports bind hardware, OS, compiler, backend, power/thermal state, transport, exclusions, confidence intervals, and effect sizes.

VIII. DISCUSSION AND LIMITATIONS

The proposed contract narrows the gap between cryptographic choice and application authority. It neither attests remote policy execution nor survives trusted-boundary compromise. It does not prove provider-failure facts, prevent all resource exhaustion, or turn a presentation fence into proof of human perception. Without an external witness, local policy and audit state may roll back with the device. Stable policy identifiers may create linkability; metadata privacy requires separate work.

The strongest planned formal result remains layered: computational combiner binding, symbolic protocol guarantees, and state-machine invariants under explicit interfaces. A full computational AKE reduction and mechanized implementation refinement would be stronger and are not implied by the proposed evidence chain.

IX. CONCLUSION

Policy-to-purpose-to-byte continuity makes application acceptance the endpoint of post-quantum migration assurance. BOUNDSESSION proposes an independently scoped contract designed to bind each endpoint's local authenticated policy decision and exact owner to one wire profile, purpose, transcript, shared grant, bilateral-ready set, and trusted purpose-specific effect receipt. Its authorization record is local diagnostic evidence, not a claim of durable non-repudiation or application success. The next milestone is not prose expansion: it is a single final-source implementation and composed evidence root that can replace the pending entries in the claim ledger without borrowing conclusions from its upstream components.

REFERENCES

- [1] C. Cremers, A. Dax, and N. Medinger, “Keeping up with the KEMs: Binding security of key encapsulation mechanisms,” in *Proc. ACM SIGSAC Conf. Computer and Communications Security*, 2024.
- [2] S. Schmieg, “Unbindable kemmy schmidt: ML-KEM is neither MAL-BIND-K-CT nor MAL-BIND-K-PK,” IACR Cryptology ePrint Archive, Paper 2024/523, 2024.
- [3] J. Krämer, P. Struck, and M. Weishäupl, “Binding security of combined KEMs: An analysis of real-world KEM combinators,” IACR Cryptology ePrint Archive, Paper 2025/1416, 2025.
- [4] E. Rescorla, “Keying material exporters for transport layer security (TLS),” RFC 5705, 2010.
- [5] S. Whited, “Channel bindings for TLS 1.3,” RFC 9266, 2022.
- [6] E. Rescorla, “The transport layer security (TLS) protocol version 1.3,” RFC 8446, 2018.
- [7] B. Moeller and A. Langley, “TLS fallback signaling cipher suite value (SCSV) for preventing protocol downgrade attacks,” RFC 7507, 2015.
- [8] E. Barker *et al.*, “Considerations for achieving crypto agility: Strategies and practices,” NIST, Tech. Rep. Cybersecurity White Paper 39, 2025.
- [9] National Institute of Standards and Technology, “FIPS 203: Module-lattice-based key-encapsulation mechanism standard,” NIST, Tech. Rep. FIPS 203, 2024.
- [10] D. Connolly, P. Schwabe, and B. Westerbaan, “X-wing: The hybrid KEM you’ve been looking for,” Internet-Draft, work in progress, 2026.
- [11] G. Barthe, B. Grégoire, S. Heraud, and S. Z. Béguelin, “Computer-aided security proofs for the working cryptographer,” in *Advances in Cryptology—CRYPTO*, 2011.
- [12] S. Meier, B. Schmidt, C. Cremers, and D. Basin, “The TAMARIN prover for the symbolic analysis of security protocols,” in *Computer Aided Verification*, 2013, pp. 696–701.
- [13] B. Blanchet, “Modeling and verifying security protocols with the applied pi calculus and ProVerif,” *Found. Trends Privacy Secur.*, vol. 1, no. 1–2, pp. 1–135, 2016.
- [14] J.-K. Zinzindohoué, K. Bhargavan, J. Protzenko, and B. Beurdouche, “HACL*: A verified modern cryptographic library,” in *Proc. ACM SIGSAC Conf. Computer and Communications Security*, 2017.
- [15] J. B. Almeida *et al.*, “Formally verifying Kyber: Episode V,” in *Advances in Cryptology—CRYPTO*, 2024.
- [16] J. H. Saltzer and M. D. Schroeder, “The protection of information in computer systems,” *Proc. IEEE*, vol. 63, no. 9, pp. 1278–1308, 1975.
- [17] M. S. Miller, K.-P. Yee, and J. Shapiro, “Capability myths demolished,” Johns Hopkins University, Tech. Rep. SRL2003-02, 2003.
- [18] H. Chen, D. Ziegler, A. Chlipala, M. F. Kaashoek, and N. Zeldovich, “Using crash hoare logic for certifying the FSCQ file system,” in *Proc. 25th ACM Symp. Operating Systems Principles*, 2015, pp. 18–37.
- [19] B. Schneier and J. Kelsey, “Secure audit logs to support computer forensics,” *ACM Trans. Inf. Syst. Secur.*, vol. 2, no. 2, pp. 159–176, 1999.